Adventures of Identity Protection

Modernizing Conditional Access Policy framework

16.4.2025 Matti Väliniemi

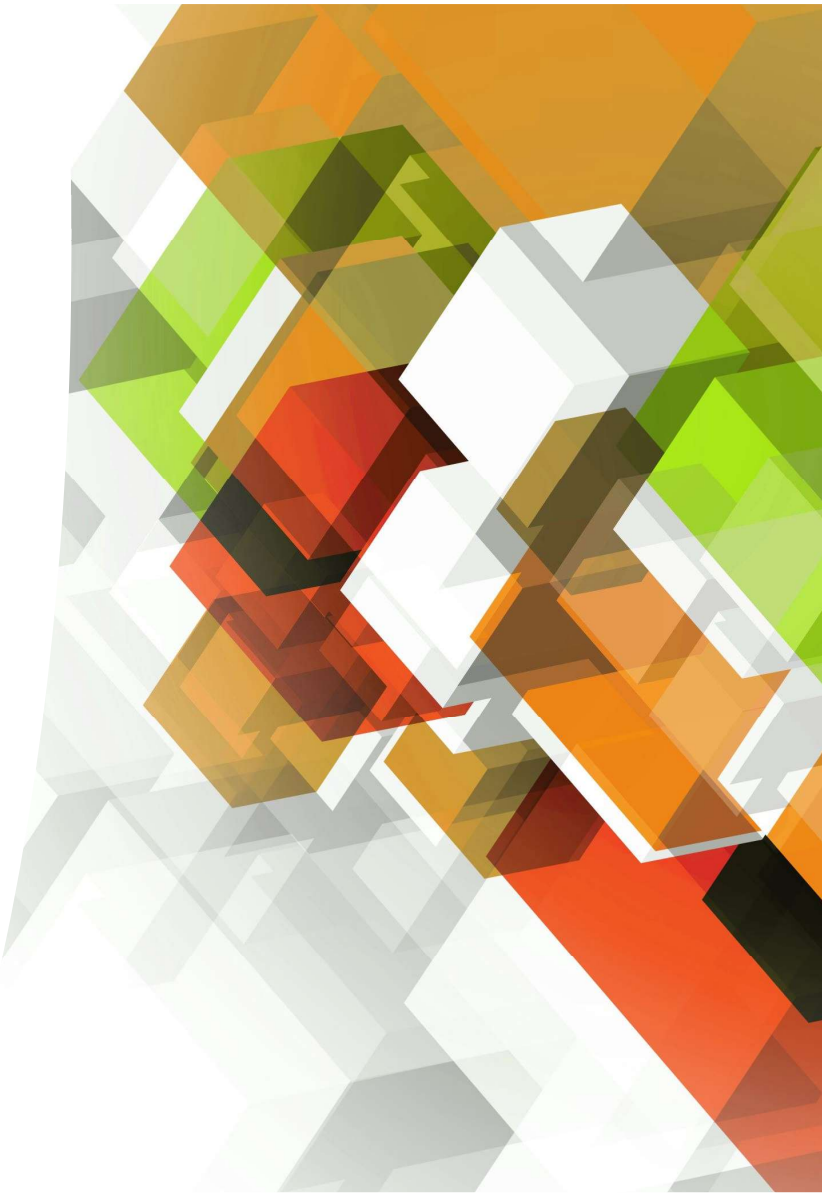
A SUSTAINABLE FUTURE THROUGH DIGITALISATION

Introduction and Agenda

Matti Väliniemi
Senior Technical Consultant
Microsoft 365, Endpoints, Security

Agenda

- Conditional Access Policy framework
- Goals
- Target methods and policies
- Design principles and planning
- Demo time:
  - Planning actual policies
  - Non-Interactive Sign-in Insights and reporting workbook
  - Creating CatchEmAll policy
- Deploying CA Policy framework
- Challenges faced & Lessons learned



Reminder

Identity is very popular attack vector

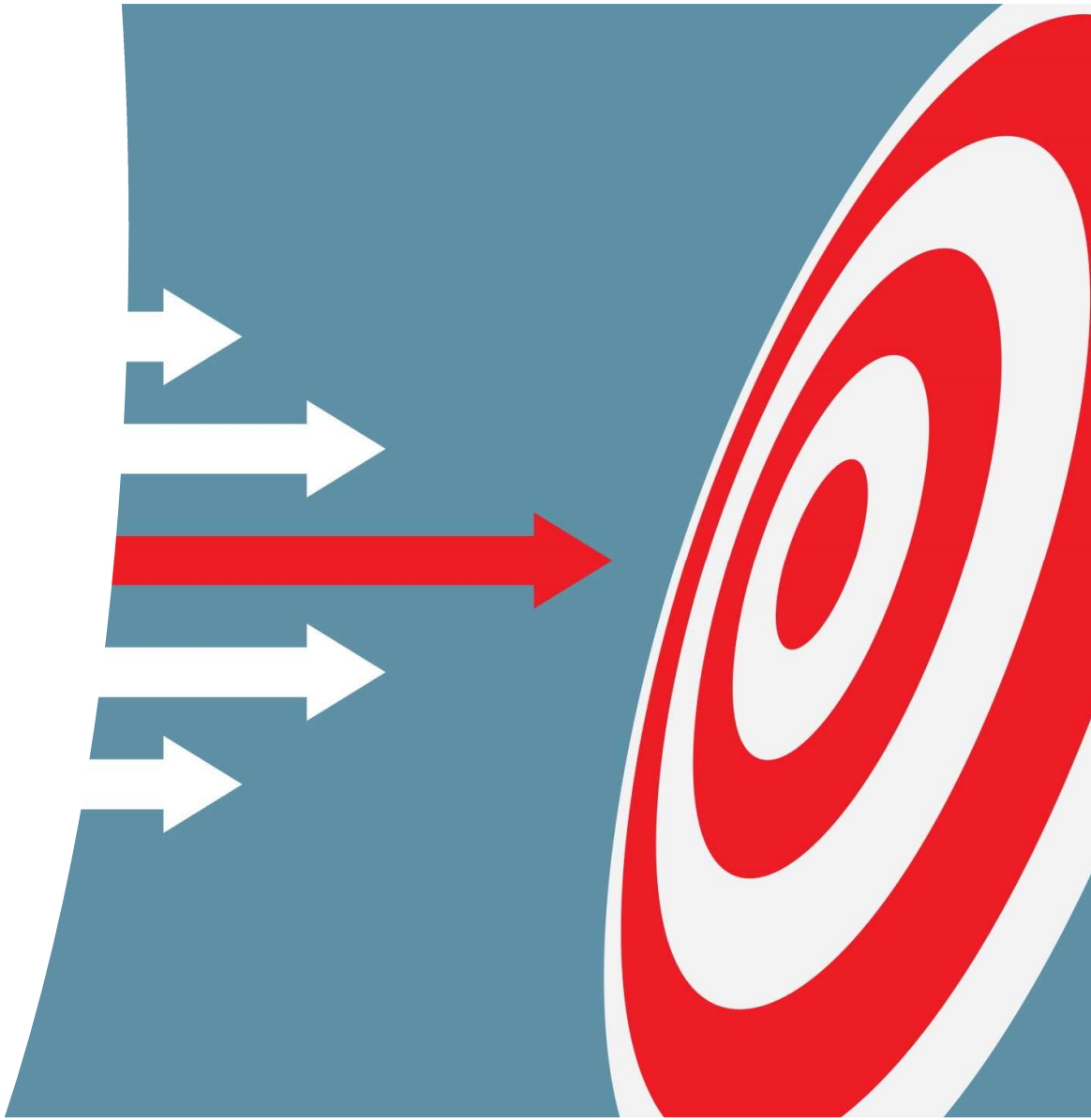
Proactive protection is important

CAP Framework and Personas

- CAP Framework = Baseline for designing CAP structure
- Persona = Target group of identities
  - Global
  - Internal
  - External
  - Guest
  - Admin
  - Shared Accounts
  - Service Accounts

Goals

- All personas have method for targeting policies
- #noexcludes
- Each user account belongs to only one target group
- Prevent sign-in if an account is not in any of the target groups



Example target methods for personas

Persona	Targeting	Suggested method
Global	All Users	CA Policy for All Users
Internal	Users that use company owned trusted devices	Dynamic Entra ID Group, based on HR data
External	Partners etc that normally use their own or their companys devices (non-trusted)	Dynamic Entra ID Group
Guest	Guest users	CA Policy selection
Admin	Admin users or administrative actions (AAD Join)	CA Policy selection for Admin roles AND Dynamic Entra ID Group of Admins
Shared Accounts	Accounts that are used by multiple persons and therefore difficult or impossible to require MFA	Entra ID Group
Service Accounts	Accounts that are not used by persons (no MFA) and usually not from compliant devices	Entra ID Group

Example policies for personas

Persona	Policy
Global	Sign-in frequency 8h when accessing from non-compliant device
Internal	Require compliant device when using Client / App, MFA with Browser
External	Require MFA
Guest	Require MFA
Admin	Require MFA, Sign-in frequency 8h
Shared Accounts	Require compliant device or known network location
Service Accounts	Require compliant device or known network location

Aim for ”No Exclucions”

- Plan CAP targeting to minimize need for exclusions
- Internal, External, Guest, Admin, Shared personas should need no exclusions to policies
- Service accounts may need to be excluded from their CAP policy when
  - Signing-in from untrusted network AND
  - Signing-in with non-compliant device
- Monitor excluded accounts extra carefully and do not add accounts to exclude group on light basis.

Importance of Guest MFA

Challenge

- When attacker gets hold of user credentials they can fairly easily see what are the guest tenants for that user
- They can login as guest without MFA if guest tenant does not require MFA for Guests

Solution

- Always require MFA from Guest users.

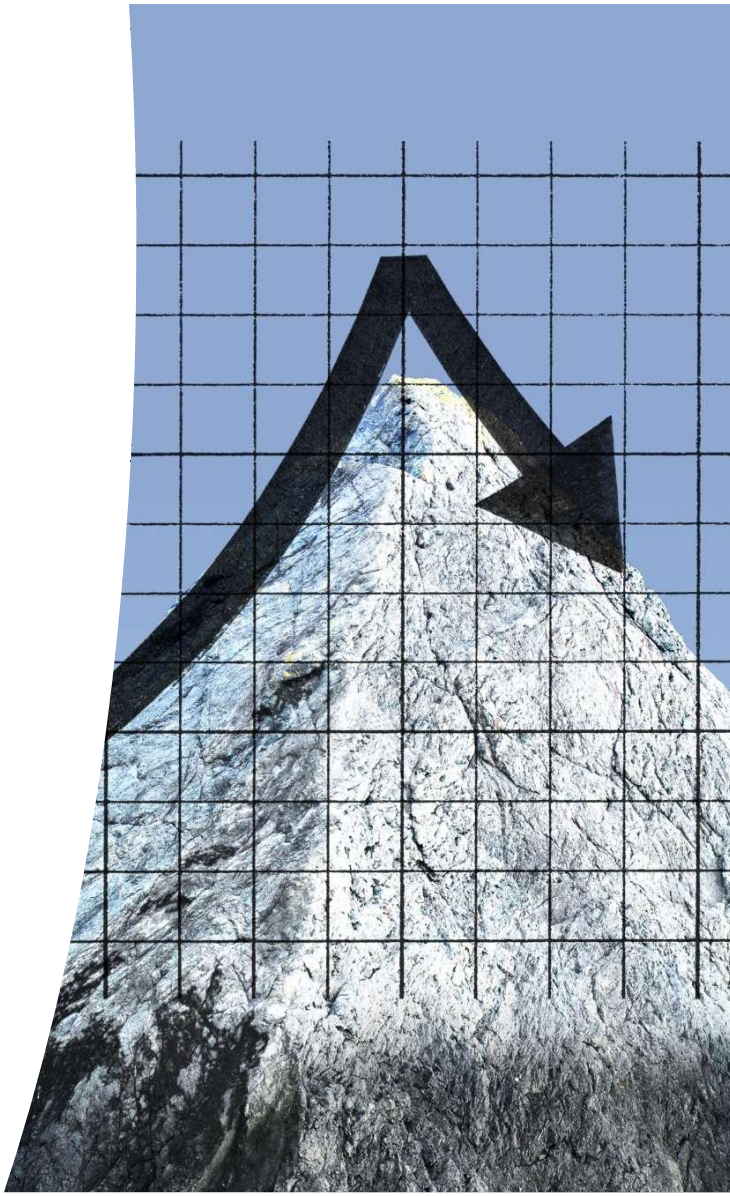
More info (shout out to Nestori Syynimaa): https://aadinternals.com/post/ests/

Gotta catch em all

Goal	Prevent sign-in from accounts that are not targeted with CA policies
Method	Create Block policy for all users and exclude all your CAP target groups / personas
Result	Rest assured that there are no holes in your CAP Framework

elisa

Well planned is half done



Non-interactive Sign-ins

Challenge

- Non-interactive sign-ins do not register in Insights and Reporting tool
- With new Outlook and Teams client even end user client authentication is now non-interactive type

Solution

- Configure custom workbook in Entra or Log analytics to evaluate policy effect in report-only mode for Non-interactive sign-ins before enabling policy

Be alert after enabling policy and have exclusion groups in place so you can add accounts when needed

Demo time

- Planning and documenting CA Policies
- Creating Insights and Reporting workbook for Non-interactive sign-ins
- Creating a CatchEmAll CA Policy

Deploying CA Policy framework

- Side-by-side with current policies
  - All policies are evaluated so no need to prioritize
- At first configure policies in Report Only mode
- CatchEmAll policy should be configured in the first phase to catch accounts that need to be assigned to some CA policy target group
- Deploy policies one persona at a time, pilot if possible
- After CatchEmAll has been deployed you can turn off all “old” policies

Challenges faced and Lessons learned

Missing Device ID

Sign-in frequency

Non-Interactive sign-ins

Importance of Guest MFA

Custom application exclude

End Users with Admin roles

Test accounts

Windows Activation

Windows Hello for Business

IPv6

elisa

Windows Activation

Challenge

Cloud licensed Windows workstations need to access activation service. This does not support Device Compliance

Solution

Exclude necessary backend applications from CA Policies

Organizations that use the Subscription Activation feature to enable users to "step-up" from one version of Windows to another and use Conditional Access policies to control access need to exclude one of the following cloud apps from their Conditional Access policies using **Select Excluded Cloud Apps**:

- Universal Store Service APIs and Web Application, AppID 45a330b1-b1ec-4cc1-9161-9f03992aa49f.
- Windows Store for Business, AppID 45a330b1-b1ec-4cc1-9161-9f03992aa49f.

Although the app ID is the same in both instances, the name of the cloud app depends on the tenant.

Custom Application Exclude

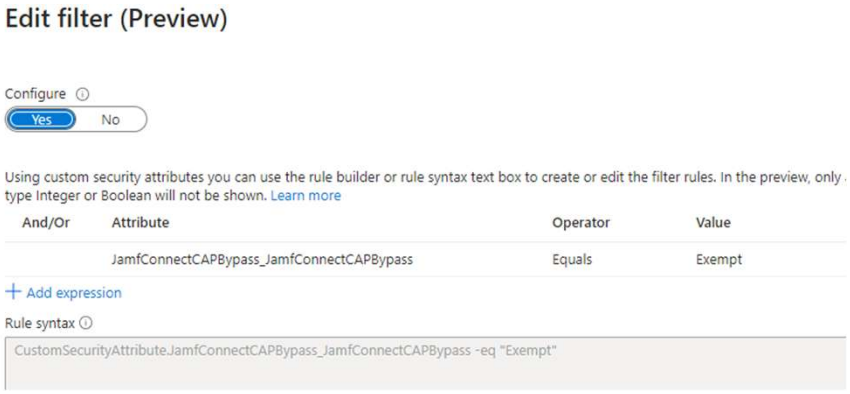
Challenge

Application (case in point: Jamf Connect) does not support device compliance and needs to be excluded from policy

Application is not available in CA Policy application list

Solution

Create custom security attribute and assign it to application in Entra. Filter CA Policy targeting based on that attribute



Windows Hello for Business

Challenge	Solution
Sign-in frequency does not have the desired effect when user has authenticated to device with WHfB	This is because WHfB is considered as strong (and phishing resistant) authentication and therefore no separate MFA request is not applied.

Sign-in frequency

Challenge	Solution
Even SSO sessions and policies without MFA request ask for MFA	Target Sign-in frequency setting only to Admin users and end users with unknown devices.

IPv6

Challenge	Solution
Service account is accessing Entra from trusted network, but uses IPv6 address and therefore is not identified correctly	If possible change the IPv6 address to IPv4 on the server and check that location is showing correctly in Entra Sign-in logs.

Test Accounts

Challenge	Solution
Test accounts hit ”CatchEmAll” policy and are blocked from signing in.	Create separate persona and target group for Test accounts as well to get them included in CA policies and excluded from CatchEmAll

Missing Device ID

Challenge	Solution
Device ID missing from authentication claim -> device identified as ”not compliant”	Exclude frontend or backend application from policy that requires compliant or hybrid joined device.
Some legacy apps might not support Device compliance (case in point: Microsoft ODBC Client)	Configure MFA requirement in place if possible

End Users with Admin roles

Challenge

Some End Users might have Admin roles assigned and therefore get the Admin CA policy effect in their regular use

Solution

Admin roles should be assigned only to Admin accounts.

Check Admin role assignments before deploying Admin role policy

Q & A

More about the subject from author: Bloggerz.cloud

elisa

elisa

A SUSTAINABLE FUTURE THROUGH DIGITALISATION